

Module - 08

Sniffing

- Sniffing: Packet Sniffing is the process of capturing and analyzing data packets as they travel across a network.
- Sniffer: Sniffer (Packet or network analyzer) is a tool that "listens" to network traffic and records everything it sees.
- Promiscuous Mode: forces the NIC to accept all packets that arrive, regardless of destination.
- Type of Sniffing:

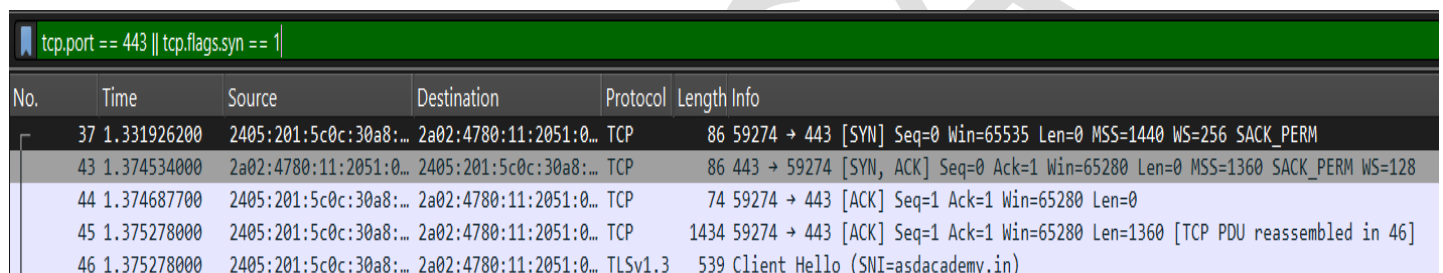
Passive Sniffing	Active Sniffing
Capturing traffic without sending any packets onto the network.	Actively injecting packets into network to force traffic to flow through your machine.
Undetectable - just listening.	Detectable - increased traffic.
Ex - Listening traffic using Wireshark or Burpsuite.	Ex - MAC Flooding, DNS Spoofing.

Wireshark Tool

→ Objective: To demonstrate the principles of network sniffing by capturing and analyzing live network traffic, specifically focusing on:

- TCP three-way handshake establishment
- HTTP protocol analysis
- Identification of sensitive data in transit

→ TCP Handshake Analysis:



The image shows a Wireshark packet capture interface. The top bar is green with the filter 'tcp.port == 443 || tcp.flags.syn == 1'. The packet list shows five packets. Packets 37, 43, and 44 are TCP packets showing the three-way handshake. Packet 45 is a TLSv1.3 packet showing the Client Hello. Packet 46 is also a TLSv1.3 packet showing the Client Hello. The packet details pane shows the structure of the TCP and TLSv1.3 packets.

No.	Time	Source	Destination	Protocol	Length	Info
37	1.331926200	2405:201:5c0c:30a8:...	2a02:4780:11:2051:0...	TCP	86	59274 → 443 [SYN] Seq=0 Win=65535 Len=0 MSS=1440 WS=256 SACK_PERM
43	1.374534000	2a02:4780:11:2051:0...	2405:201:5c0c:30a8:...	TCP	86	443 → 59274 [SYN, ACK] Seq=0 Ack=1 Win=65280 Len=0 MSS=1360 SACK_PERM WS=128
44	1.374687700	2405:201:5c0c:30a8:...	2a02:4780:11:2051:0...	TCP	74	59274 → 443 [ACK] Seq=1 Ack=1 Win=65280 Len=0
45	1.375278000	2405:201:5c0c:30a8:...	2a02:4780:11:2051:0...	TCP	1434	59274 → 443 [ACK] Seq=1 Ack=1 Win=65280 Len=1360 [TCP PDU reassembled in 46]
46	1.375278000	2405:201:5c0c:30a8:...	2a02:4780:11:2051:0...	TLSv1.3	539	Client Hello (SNI=asdacademy.in)

Packet No.	Protocol	Info
37	TCP	59274 → 443 [SYN]
43	TCP	443 → 59274 [SYN, ACK]
44	TCP	59274 → 443 [ACK]
45	TLSv1.3	59274 → 443 [ACK]
46	TLSv1.3	Client Hello (SNI= asdacademy.in)

→ HTTP POST Request Analysis:

No.	Time	Source	Destination	Protocol	Length	Info
27	1.347129019	192.168.29.8	65.61.137.117	HTTP	640	POST /doLogin HTTP/1.1 (application/x-www-form-urlencoded)
29	1.726003479	65.61.137.117	192.168.29.8	HTTP	192	HTTP/1.1 302 Found
32	1.733990551	192.168.29.8	65.61.137.117	HTTP	500	GET /login.jsp HTTP/1.1

Frame 27: Packet, 640 bytes on wire (5120 bits), 640 bytes captured	0000	f0 ed b8 48 01 78 00 0c	29 72 f4 4c 08 00 45 00	...H.x...r
Ethernet II, Src: VMware_72:f4:4c (00:0c:29:72:f4:4c), Dst: Servercc	0010	02 72 de 29 40 00 40 06	b1 f9 c0 a8 1d 08 41 3d	.r.)@.@...
Internet Protocol Version 4, Src: 192.168.29.8, Dst: 65.61.137.117	0020	89 75 96 8a 00 50 16 8f	35 5f 9b bb df 2d 80 18	.u...P...5_
Transmission Control Protocol, Src Port: 38538, Dst Port: 80, Seq: 1	0030	00 fb aa c7 00 00 01 01	08 0a 1f a6 4a 43 01 d2	
Hypertext Transfer Protocol	0040	40 fd 50 4f 53 54 20 2f	64 6f 4c 6f 67 69 6e 20	@ POST / do
HTML Form URL Encoded: application/x-www-form-urlencoded	0050	48 54 54 50 2f 31 2e 31	0d 0a 48 6f 73 74 3a 20	HTTP/1.1 ..l
Form item: "uid" = "Anjali"	0060	74 65 73 74 66 69 72 65	2e 6e 65 74 0d 0a 55 73	testfire .n
Form item: "passw" = "User@123"	0070	65 72 2d 41 67 65 6e 74	3a 20 4d 6f 7a 69 6c 6c	er-Agent : l
Form item: "btnSubmit" = "Login"	0080	61 2f 35 2e 30 20 28 58	31 31 3b 20 4c 69 6e 75	a/5.0 (X 11
	0090	78 20 78 38 36 5f 36 34	3b 20 72 76 3a 31 34 30	x x86 64 ;

Packet No.	Protocol	Length	Info
27	HTTP	640	POST /doLogin HTTP/1.1
29	HTTP	192	HTTP/1.1 302 Found
32	HTTP	500	GET /login.jsp HTTP/1.1

Credential Captured:

Field	Value
uid	Anjali
passw	User@123

MITM - ARP Spoofing

→Objective: To demonstrate a Man-in-the-Middle (MITM) attack using ARP Spoofing where the attacker intercepts network traffic between the victim and the gateway, capturing sensitive information such as login credentials in transit.

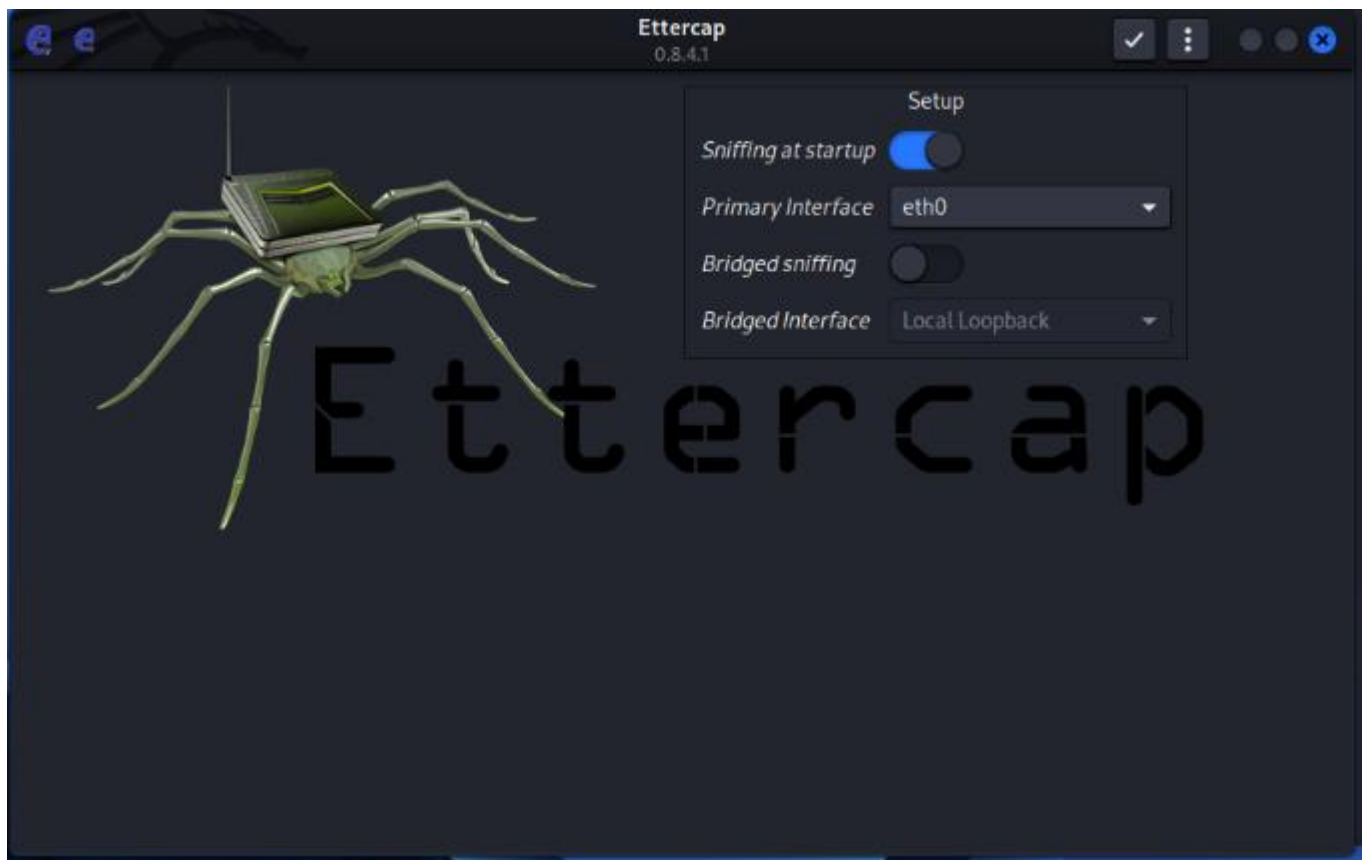
→Lab Environment:

Component	Details
Attacker Machine	Kali Linux (192.168.29.48)
Victim Machine	Windows (192.168.29.205)
Gateway/Router	192.168.29.1
Tool Used	Ettercap (GUI version 0.8.4.1)
Target Website	http://testfire.net/login.jsp (AltoroMutual Banking Demo)

→ARP: ARP (Address Resolution Protocol) is a fundamental network protocol that maps IP addresses (Layer 3) to MAC addresses (Layer 2). When a device wants to communicate with another device on the same network, it sends an ARP request asking "Who has this IP address?" The device with that IP responds with its MAC address.

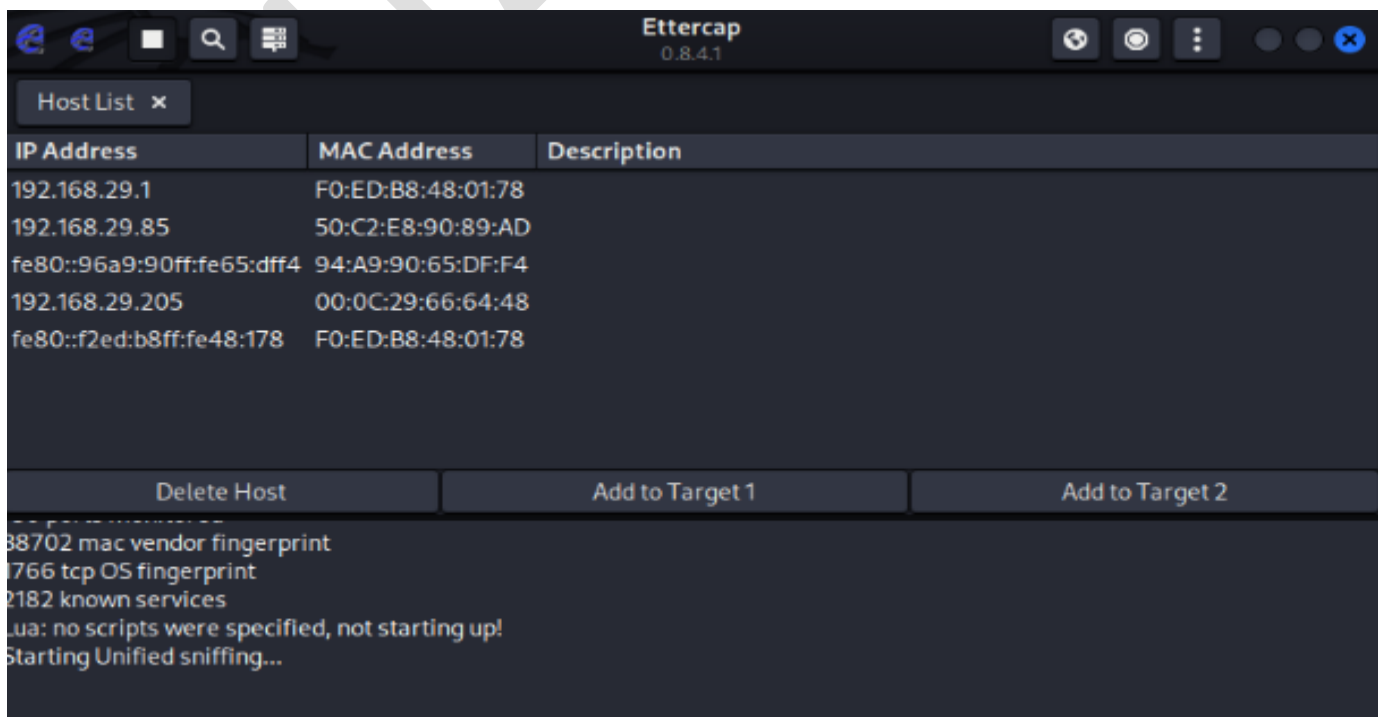
→ Attack Execution:

Step 1: Launch Ettercap

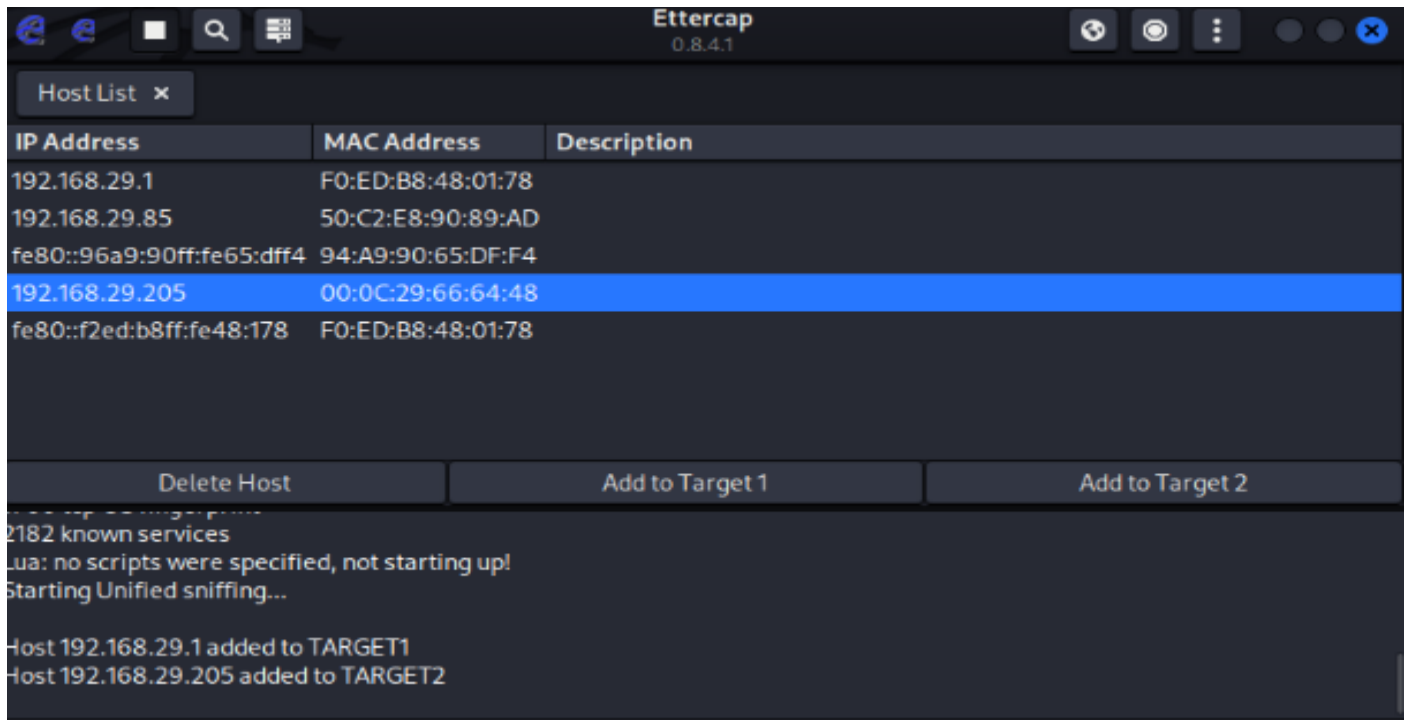


Step 2: Scan Network for Hosts

[: -> Host List]

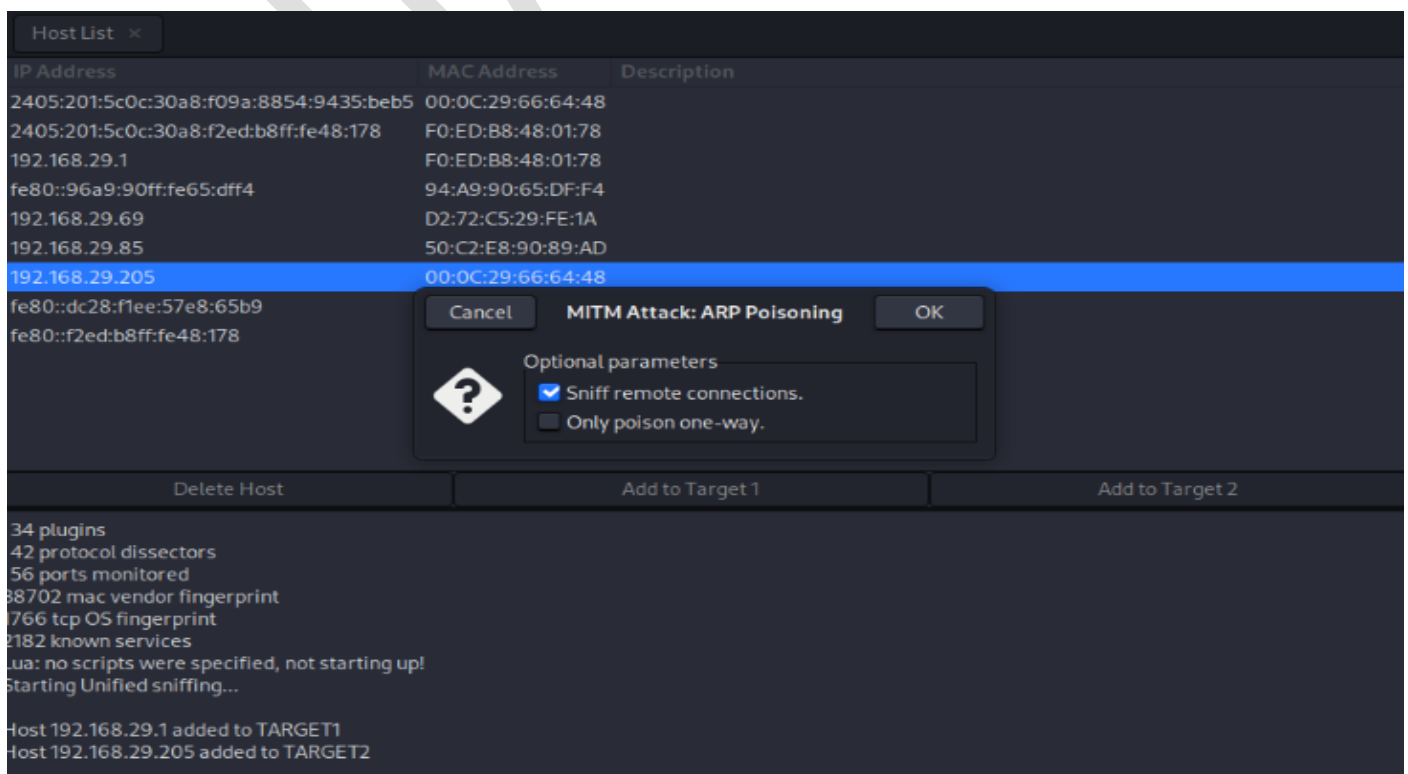


Step 3: Select Targets



- Selected 192.168.29.1 → Clicked Add to Target 1 (Gateway)
- Selected 192.168.29.205 → Clicked Add to Target 2 (Victim)
- By poisoning both, we become the Man-in-the-Middle

Step 4: Launch ARP Poisoning Attack



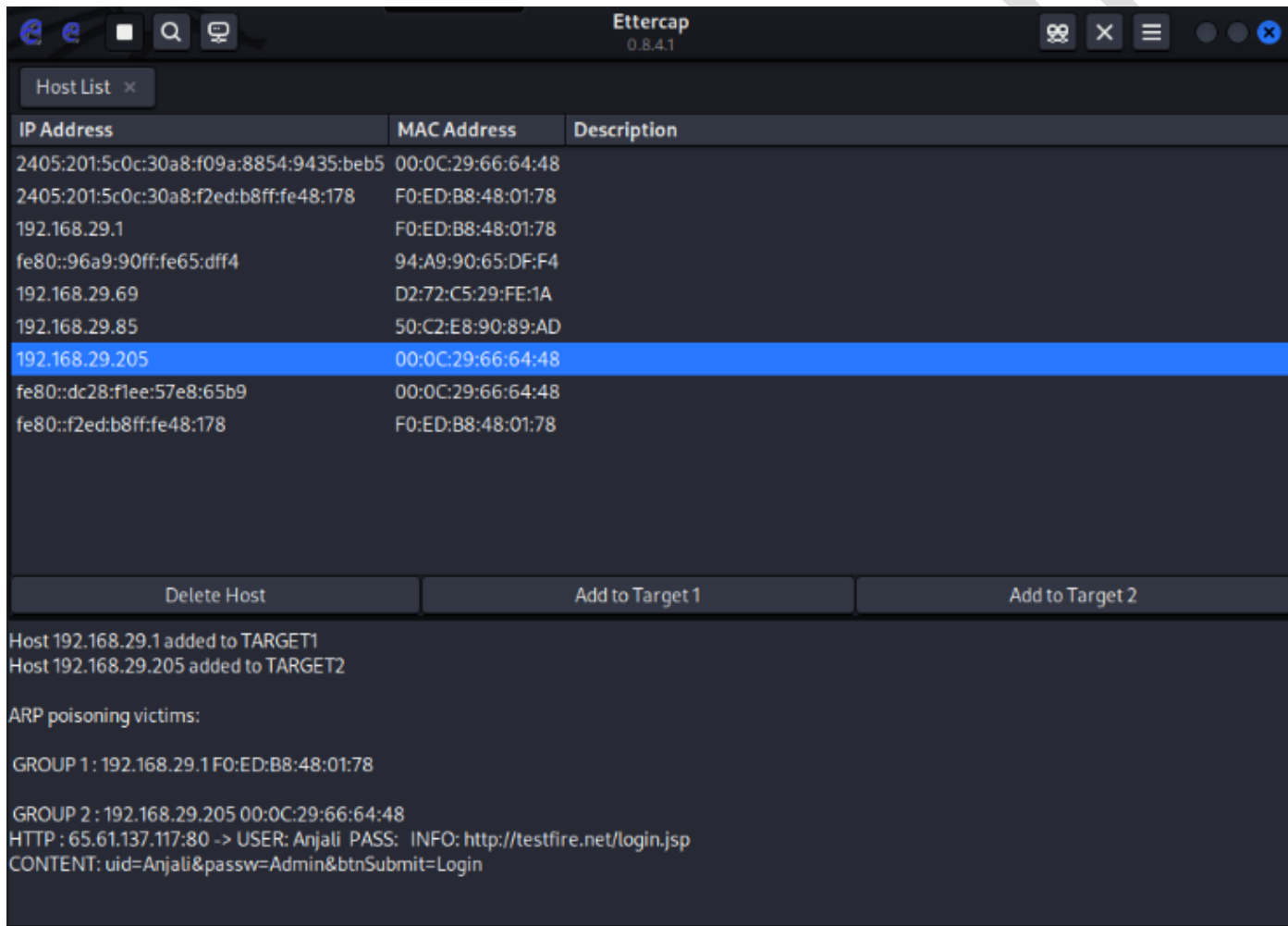
```
Host 192.168.29.1 added to TARGET1
Host 192.168.29.205 added to TARGET2

ARP poisoning victims:

GROUP 1 : 192.168.29.1 F0:ED:B8:48:01:78

GROUP 2 : 192.168.29.205 00:0C:29:66:64:48
```

Step 5: Capturing Credential in Transit



The screenshot shows the Ettercap 0.8.4.1 interface. At the top, a status bar indicates 'Host 192.168.29.1 added to TARGET1' and 'Host 192.168.29.205 added to TARGET2'. Below this, a table titled 'Host List' displays the following data:

IP Address	MAC Address	Description
2405:201:5c0c:30a8:f09a:8854:9435:beb5	00:0C:29:66:64:48	
2405:201:5c0c:30a8:f2ed:b8ff:fe48:178	F0:ED:B8:48:01:78	
192.168.29.1	F0:ED:B8:48:01:78	
fe80::96a9:90ff:fe65:dff4	94:A9:90:65:DF:F4	
192.168.29.69	D2:72:C5:29:FE:1A	
192.168.29.85	50:C2:E8:90:89:AD	
192.168.29.205	00:0C:29:66:64:48	
fe80::dc28:flee:57e8:65b9	00:0C:29:66:64:48	
fe80::f2ed:b8ff:fe48:178	F0:ED:B8:48:01:78	

Below the table, there are three buttons: 'Delete Host', 'Add to Target 1', and 'Add to Target 2'. At the bottom, a text area displays the following information:

```
Host 192.168.29.1 added to TARGET1
Host 192.168.29.205 added to TARGET2

ARP poisoning victims:

GROUP 1 : 192.168.29.1 F0:ED:B8:48:01:78

GROUP 2 : 192.168.29.205 00:0C:29:66:64:48
HTTP : 65.61.137.117:80 -> USER: Anjali PASS: INFO: http://testfire.net/login.jsp
CONTENT: uid=Anjali&passw=Admin&btnSubmit=Login
```

Credentials Captured by Ettercap:

- uid = Anjali (Username)
- passw = Admin (Password)
- btnSubmit = Login (Form submission)
- Website: <http://testfire.net/login.jsp>
- Method: HTTP POST (Plaintext transmission)

→ MITM: Man-in-the-Middle is an attack where the attacker secretly intercepts, relays, and potentially alters communication between two parties who believe they are communicating directly with each other.

The MITM Attack Goals:

1. Intercept - Capture all traffic between victim and server
2. Analyze - Extract sensitive information (passwords, session cookies)
3. Relay - Forward traffic to maintain normal communication
4. Remain Invisible - Neither victim nor server detects interception

Phase 1: Scan

Attacker scans network (Ettercap) → Discovers Hosts

- Identifies Gateway (192.168.29.1) and Victim (192.168.29.205)

Phase 2: Poison

Attacker sends spoofed ARP replies to:

- Victim: "Gateway IP 29.1 is at ATTACKER MAC"
- Gateway: "Victim IP 29.205 is at ATTACKER MAC"

Phase 3: MITM

All traffic between Victim and Gateway flows through Attacker
Attacker is now the Man-in-the-Middle

Phase 4: Capture

Attacker sniffs traffic → Victim logs into website

- HTTP POST captures credentials → Attacker sees username/pass

Phase 5: Maintain

Attacker continues to relay traffic and sniff for more data
Connection remains active and undetected

→ Post-Attack Evidence [Windows - Victim Machine]

```
C:\Users\USER>arp -a

Interface: 192.168.29.205 --- 0x4
Internet Address      Physical Address      Type
192.168.29.1          00-0c-29-fa-24-be     dynamic
192.168.29.48         00-0c-29-fa-24-be     dynamic
192.168.29.255        ff-ff-ff-ff-ff-ff     static
224.0.0.22            01-00-5e-00-00-16     static
224.0.0.251           01-00-5e-00-00-fb     static
224.0.0.252           01-00-5e-00-00-fc     static
239.255.255.250       01-00-5e-7f-ff-fa     static
255.255.255.255       ff-ff-ff-ff-ff-ff     static

C:\Users\USER>
```

Critical Finding - ARP Cache Poisoning Detected!

Field	Value	Analysis
Internet Address	192.168.29.1	Gateway IP Address
Physical Address	00-0c-29-fa-24-be	MAC Address (Attacker's?)
Type	dynamic	Entry was learned via ARP (not static)

- **DUPLICATE MAC ADDRESS!** - Two Different IP Addresses have same MAC Address.
- Clear Indicator of ARP Spoofing.